SEGREGAÇÃO DE FUNÇÕES DE TI (POLÍTICA)

Índice

1. Objetivo 3
2. Alcance 3
3. Definições e Abreviaturas 3
4. Autoridades e Responsabilidades 3
5. Regras Gerais 4
6. Princípios de Segregação de Funções 4
7. Ações Compensatórias para Eliminação ou Mitigação de Conflitos 4
8. Matriz de Conflitos - Modelos 5
9. Referências 6
10. Sanções e Penalidades 6
11. Controle de Revisões 6

1. Objetivo

- Estabelecer os princípios e diretrizes de Segregação de Funções de TI a serem aplicados.

2. Alcance

- Processos da Área de TI (Tecnologia da Informação) da SMILES S.A.

3. Definições e Abreviaturas

- **Segregação de Funções**: princípio básico de controle interno, essencial para a sua efetividade. Consiste na separação de atribuições ou responsabilidades entre diferentes funções/papéis, especialmente relacionado e aplicado às funções e atividades-chave de autorização/aprovação, execução, validação/conferência ou auditoria. Também conhecido por *Segregation of Duties* ou simplesmente pela sigla *SoD*.

- **Processo**: conjunto estruturado de atividades destinadas a atingir um objetivo específico. Um processo tem uma ou mais entradas definidas e as transforma em saídas definidas.

- **Papel**: Um conjunto de procedimentos ou ações conectadas que são realizadas por uma pessoa, equipe ou grupo em um contexto específico.

- **Atividade do Processo**: equivale à realização/concretização de uma tarefa. De forma agrupada, refere-se ao conjunto de ações para atingir um resultado específico, normalmente definidas como parte de processos e documentadas em procedimentos.

- **Atividade Crítica de Processo**: equivale a uma tarefa de alta relevância/importância para o atingimento dos resultados de um processo.

- **Dono do Processo**: papel exercido por um Colaborador Smiles com pleno conhecimento das atividades e funções exercidas em um determinado processo de gestão.

- **TI**: acrônimo para Tecnologia da Informação.

4. Autoridades e Responsabilidades

- **Segurança da Informação**: responsável pela Política de Segregação de Funções de TI e sua aplicabilidade.

- **Dono do Processo**: responsável pela análise dos princípios de segregação de funções em face ao processo de sua responsabilidade, identificação de conflitos e ações de eliminação ou mitigação dos mesmos.

5. Regras Gerais

- Deve ser elaborada uma Matriz de Conflitos para o processo a ser avaliado, de forma a servir de ferramenta para identificação os conflitos de função. O modelo da matriz se encontra em seção específica deste documento.

- Durante a identificação de conflitos, as atividades do processo devem ser classificadas entre as opções:

    - **Executa**: atividades relacionadas à realização/execução de tarefas do processo.
    - **Aprova**: atividades de aprovação/autorização (tomada de decisão) do processo.
    - **Valida**: as atividades de checagem ou conferência de tarefas anteriores do processo.

- Durante a identificação de conflitos, o Dono do Processo deve indicar quais são as Atividades Críticas do processo.

- Deverão ser avaliadas ações de eliminação ou mitigação para cada conflito de funções identificado.

6. Princípios de Segregação de Funções

Os princípios de segregação de funções definidos são:

- [P.1] – A Função ou Papel que **APROVA** uma Atividade, não pode ter **EXECUTADO** ou **VALIDADO** a atividade anterior.

- [P.2] – A Função ou Papel que **VALIDA** uma Atividade, não pode ter **APROVADO** ou **EXECUTADO** a atividade anterior.

- [P.3] – Um processo que possua apenas atividades de execução, precisa ser revisado para contemplar, ao menos, uma atividade de validação (conferência) ou aprovação (autorização).

- [P.4] – Um mesmo Recurso / Cargo não pode compor ou fazer parte, isoladamente, de todos os Papéis / Funções de um processo.

7. Ações Compensatórias para Eliminação ou Mitigação de Conflitos

Ações ou controles de compensação a serem considerados para eliminação ou mitigação de conflitos podem ser, mas sem se limitar a:

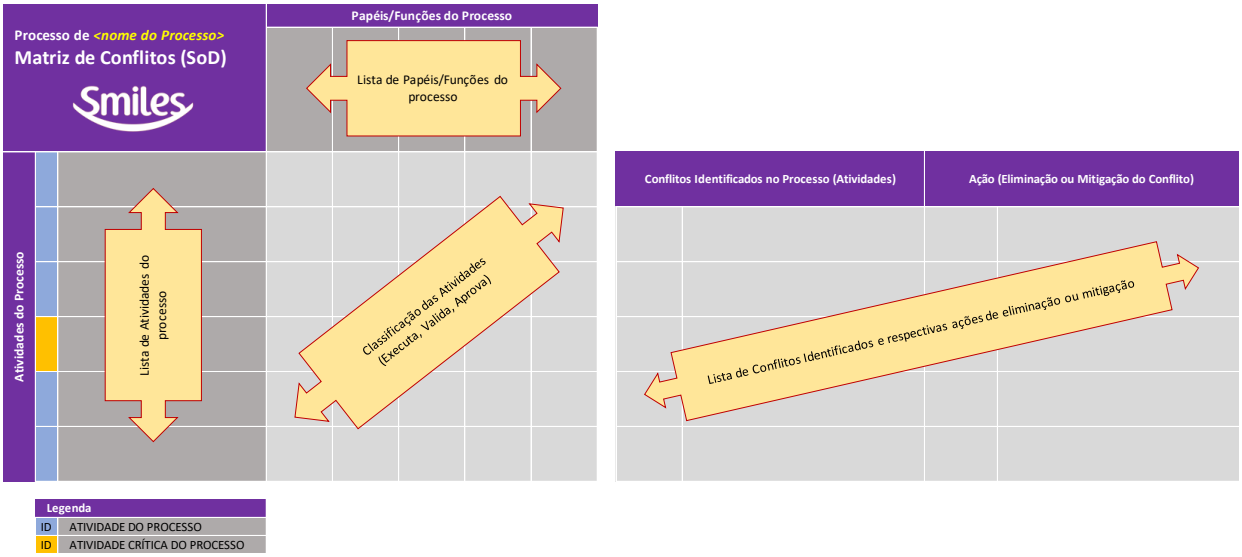
- **Monitoramento de Atividades** (supervisão da atividade enquanto em progresso);

- **Trilhas de Auditoria** ("log"/registro para rastreabilidade da atividade considerando determinadas informações, tais como quem iniciou o evento, a hora e data, etc.);

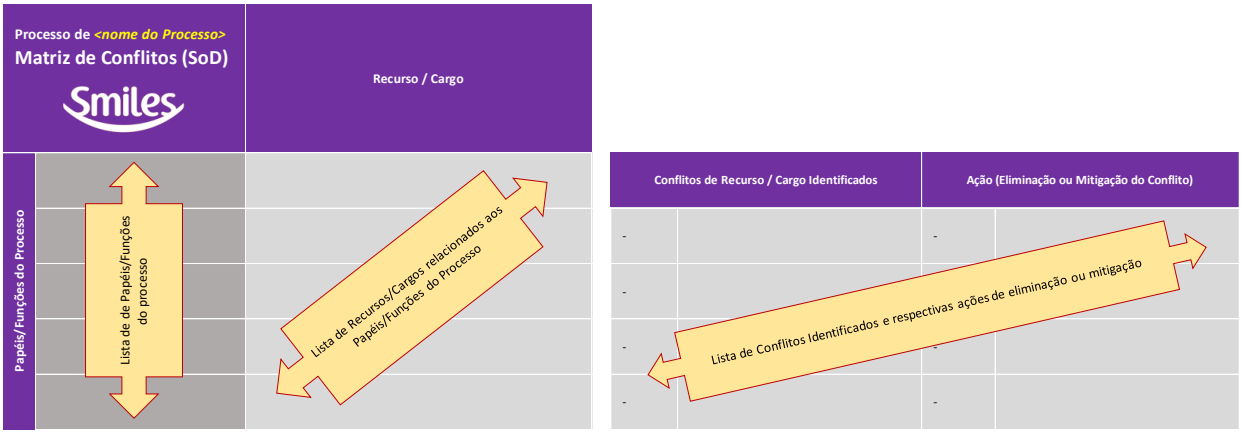
- **Aprovação Adicional** (dois ou mais aprovadores adicionais);
- **Validação Adicional** (duas ou mais validações/conferências adicionais);
- **Alteração do Recurso/Cargo** para cumprimento de determinado Papel/Função;
- Entre outras.

8. Matriz de Conflitos - Modelos

- Matriz para avaliação de conflitos entre Atividades x Papéis/Funções do Processo:



- Matriz para avaliação de conflitos entre Papéis/Funções do Processo x Recursos/Cargos relacionados:



9. Referências

- Revista do TCU (Tribunal de Contas da União) – Set/Dez 2013
- COBIT v4.1 (*Control Objectives for Information and related Technology*)
- ISO/IEC 27001 (*Information Security Management Systems - Requirements*)
- ISO/IEC 27002 (*Code of Practice for Information Security Management*)

10. Sanções e Penalidades

- O descumprimento ou não observância em relação às regras e diretrizes deste documento poderá ocasionar a abertura de um Incidente de Segurança da Informação.

11. Controle de Revisões

Versão	Data	Páginas Afetadas	Principais Alterações
1.0	25/04/2017	Todas	Definição inicial do documento.